

ET 8202: INTRODUCTION TO IS SECURITY

LECTURE 04

CYBER SECURITY THREAT LANDSCAPE

Stenography Concepts

What is Stenography?

- ❖ **Stenography** is a method of writing in shorthand. The word comes from the Greek words **stenos** (narrow) and **graphein** (to write). Stenography is also known as brachygraphy and tachygraphy.
- ❖ Stenography is based on the **pronunciation** of words. For example, to write the word "cat" in stenography, you would press "KAT" at the same time. The "K" represents the "C" sound in "cat".
- ❖ Steganography is about concealing the existence of messages.

What is Stenography?

- ❖ Steganography simply **takes one piece of information and hides it within another.**
- ❖ Steganography takes advantage of these areas, replacing them with information (encrypted mail, for instance).
- ❖ The files can then be exchanged without anyone knowing what really lies inside of them.

Security Concepts

What is Computer Security?

- ❖ **Security** is the process of maintaining an **acceptable** level of perceived risk.
 - ✓ **Risk**: a situation involving exposure to danger, harm, or loss.
- ❖ **Computer security**: Protection of computers hardware, software, data, information and other related computer devices, from theft, corruption, or natural disaster destruction.
 - ✓ A state of well-being of information and infrastructure in which the possibility of theft, tempering, and disruption of information and services is kept **low** or **tolerable**.
- ❖ **Computer security** is concern with protecting a computer system's information **assets**, as well as the computer systems themselves.
 - ✓ Asset = item of value; include: **Hardware, Software, Data**
- ❖ **Cybersecurity** is the body of technologies, processes and practices designed to protect networks, computers, programs and data from attack, damage or unauthorized access.
 - ✓ **Cyber**: it is a combination form relating to information technology, the internet and virtual reality.

Specialized Areas of Security

- ❖ **Physical security:** Protect the physical items, objects, or areas of an organization from unauthorized access and misuse.
- ❖ **Personal security:** Protect the individual or group of individuals who are authorized to access the organization and its operations.
- ❖ **Communications security:** Protect an organization's communications media, technology, and content.
- ❖ **Network Security:** Protect the network and the network-accessible resources from unauthorized access, consistent and continuous monitoring and measurement of its effectiveness.
- ❖ **Data security:** Data security is the means of ensuring that data is kept safe from corruption and that access to it is suitably controlled.

The Vulnerability – Threat – Control Paradigm

- ❖ A major goal of information security as a discipline and as a profession is to protect valuable assets. To study methods of asset protection, we use vulnerability – threat – control framework:
- ❖ **Vulnerability**
 - ✓ Is a weakness in an information system or its components that might be **exploited** to compromise the security of the system.
 - ✓ **Attack** is the deliberate act that exploits vulnerability. Is the actual attempt to violate security.
- ❖ **Threat**
 - ✓ A set of circumstances or events that has the potential to cause loss or harm of information system by destroying it, disclosing the information stored on the system, adversely modifying data, or making the system unavailable.
- ❖ **Control**
 - ✓ An action, device, procedure, or technique that eliminates or reduces a vulnerability. Also called a countermeasure.

Why Information systems are vulnerable?

1. **Poor system management:** If managers at all levels don't make security, their number one priority, then the threats to an information system is easily to become real.
2. **Familiarity:** Using common, well-known code, software, operating systems, and/or hardware increases the probability an attacker to have the tools or knowledge to exploit the weakness.
3. **Poor System Design:** If the System Analyst did not consider the security aspect, during system design process then creates a loop hole for an attacker to damage a system.
3. **Poor Password management:** The computer users stores the password on the computer or open place where an attacker can access it.
5. **Default configuration:** of the OS and Network Operating System (NOS), network devices firewalls and encryption weaknesses.

Threats and C-I-A

- ❖ Threats can apply to the confidentiality, integrity, or availability (C-I-A) of a system
 - ❖ **Confidentiality:** Assurance that the information is accessible only to those **authorized to have access**.
 - ❖ **Integrity:** The **trustworthiness of data** of resources in terms of preventing improper and unauthorized changes.
 - ❖ **Availability:** Assurance that the systems are accessible when **required by the authorized users**.
-
- C-I-A = The security Triad
 - C-I-A = The Goals/Objectives of Information Security

Additional Pillars of Information Security

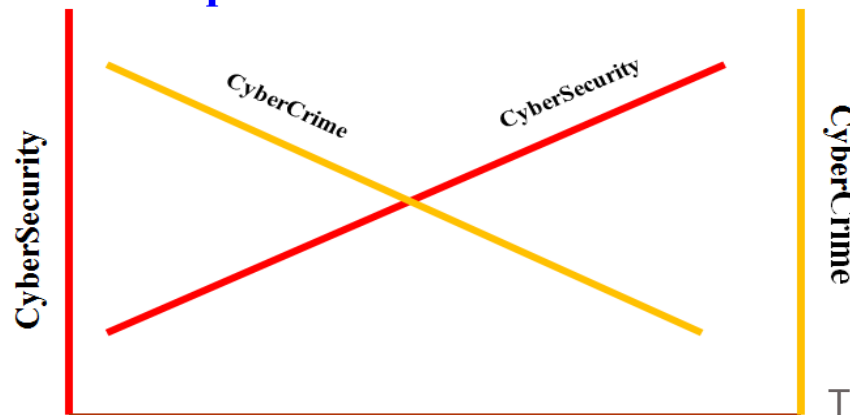
- ❖ Aside from C-I-A, authentication, nonrepudiation, and auditability are also desirable system properties
- ❖ **Authentication:** The ability of a system to confirm the identity of a sender.
- ❖ **Nonrepudiation:** The ability of a system to confirm that a sender cannot convincingly deny having sent a message.
- ❖ **Auditability:** The ability of a system to trace all actions related to a given asset.
 - ✓ Determine who did what and when in order to ensure that responsible parties are held account.

Cybercrime

Cyber Crime vs Cybersecurity

- ❖ **Computer crime:** any act directed against computers or that uses computers as an instrumentality of a crime.
 - ✓ United Nations refers it to an acts of fraud, forgery and unauthorized access. Unlawful acts wherein the computer is either a tool or a target or both.
- ❖ **Cybercrime** encompasses any criminal act dealing with computers and networks (called hacking). Additionally, cyber crime also includes traditional crimes conducted through the Internet.’
 - ✓ Cybercrime offenses ranging from criminal activity against data to content and copyright infringement.
- ❖ **Cybersecurity** is the body of technologies, processes and practices designed to protect networks, computers, programs and data from attack, damage or unauthorized access.

VS Graph - two sides of the same coin



Who Are the Cyber Criminals?

- ❖ In the early years of the cybersecurity world, the typical cyber criminals were teenagers or hobbyists operating from a home PC, with attacks mostly limited to pranks and vandalism.
- ❖ Today, the world of the cyber criminals has become more dangerous.
- ❖ Attackers are individuals or groups who attempt to exploit vulnerabilities for personal or financial gain.
- ❖ Cyber criminals are interested in everything from credit cards to product designs, and anything with value.

Threat Actors



- ❖ **Amateurs** or script kiddies,
 - ✓ Opportunistic attackers
 - ✓ Script kiddies: the term emerged in the 1990s and refers to teenagers or inexperienced hackers running existing scripts, tools, and exploits that could cause harm. It was typically not done for profit.
 - ✓ Have little or no skill, often using existing tools, password or instructions found on the Internet to launch attacks.
 - ✓ Some are just curious, while others try to demonstrate their skills and cause harm.
 - ✓ They may be using basic tools, but the results can still be devastating.

Threat Actors

❖ Hackers

- ✓ This group of criminals breaks into computers or networks to gain access for various reasons.
- ✓ The intent of the break-in determines the classification of these attackers as white, gray, or black hats.

Hacker Classes

1. **White Hats Hackers:** Individuals professing hacker skills and using them for defensive purposes and are also known as **security analyst**.
 - ✓ White hat hackers are ethical hackers who use their programming skills for good, ethical and legal purposes. White hat attackers break into networks or computer systems to discover weaknesses in order to improve the security of these systems. The owners of the system give permission to perform the break-in, and they receive the results of the test. Some organizations award prizes or bounties to white hat hackers when they inform them of a vulnerability.

Hacker Classes

2. **Black hats:** Individuals with extraordinary computing skills, resorting to malicious or destructive activities and are also known as **crackers**.
 - ✓ Black hat hackers are unethical criminals who violate computer and network security for illegal personal, financial or political gain. Black hat hackers exploit vulnerabilities to compromise computer and network systems.

Hacker Classes

3. **Gray hats:** Individuals who work both offensively and defensively at various times.
 - ✓ Gray hat attackers are somewhere between white and black hat attackers. Gray hat hackers commit crimes and do arguably unethical things, but not for personal gain or to cause damage. The gray hat attackers may find a vulnerability and report it to the owners of the system if that action coincides with their agenda. Some gray hat hackers publish the facts about the vulnerability on the Internet, so that other attackers can exploit it or allows the affected organization to fix the problem

Threat Actors

❖ Organized Hackers

✓ These criminals include

1. Organizations of cyber criminals,
2. Hacktivists,
3. Cyber terrorists, and
4. State-sponsored hackers.

Cyber criminals

- ❖ Cyber criminals: these are black hat hackers who are either self-employed or working for large cybercrime organizations.
- ❖ Cyber criminals are usually groups of professional criminals focused on control, power, and wealth. The criminals are highly sophisticated and organized, and may even provide cybercrime as a service.
- ❖ Each year, cyber criminals are responsible for stealing billions of dollars from consumers and businesses.

Hacktivists

- ❖ Hacktivists: these are gray hat hackers who rally and protest against different political and social ideas.
- ❖ Hacktivists make political statements to create awareness to issues that are important to them. Hacktivists publically publish embarrassing information about their victims.
- ❖ Hacktivists publically protest against organizations or governments by posting articles, videos, leaking sensitive information, and performing distributed denial of service (DDoS) attacks.



Kigogo  @kigogo2014 · Jun 17

👉 Sina kumbukumbu vizuri juu ya kesi za Lissu hapo Kisutu! Lakini kuna kesi inafukuliwa na atahukumiwa haraka exparte ndani ya 3-4 weeks toka sasa
👉 Akikanyaga tu Tanzania ni jela..

Muwe na mchana mwema watu wa Mungu naweni mikono corona ipo bado

💬 219

↻ 267

❤ 4.5K

📅 Tuesday, December 5, 2023

State-sponsored

- ❖ State-sponsored: depending on a person's perspective, these are either white hat or black hat hackers who steal government secrets, gather intelligence, and sabotage networks.
- ❖ State-supported spies and information warriors attackers gather intelligence or commit sabotage on behalf of their government. These attackers are usually highly trained and well-funded.
- ❖ Their attacks focus on specific goals that are beneficial to their government. Some state-sponsored attackers are even members of their nations' armed forces.
- ❖ Their targets are foreign governments, terrorist groups, and corporations.

Method of Defense

- Six approaches to defense of computing systems
 1. Prevent attack: Block attack / close vulnerability
 2. Deter attack: Make attack harder (if we can't make it impossible)
 3. Deflect attack: Make another target more attractive than this target
 4. Mitigate attack: Make the impact of an attack less severe
 5. Detect attack: during or after
 6. Recover from attack

HACKING PHASES

1. **Reconnaissance:** Reconnaissance refers to the preparatory phase where an attacker seeks to gather information about a target prior to launching an attack.
2. **Scanning:** Scanning refers to the pre-attack phase when the attacker scans the network for specific information on the basis of information gathered during reconnaissance.
3. **Gaining Access:** Gaining access refers to the point where the attacker obtains access to the operating system or applications on the computer or network.
4. **Maintaining Access:** Maintaining Access refers to the phase when the attacker tries to retain his or her ownership of the system.
5. **Covering Track:** Covering Tracks refers to the activities carried out by an attackers to hide malicious acts.

Penetration Testing

- ❖ A pentest simulates methods that intruders use to gain **unauthorized access** to an organization's networked systems and then compromise.
- ❖ Identify the threats facing an organization's information assets
- ❖ In the context of penetration testing, the tester is limited by resources: **namely time, skilled resources, and access to equipment**- as outlined in the penetration testing agreement.
- ❖ Two types of testing
 1. **External Testing**
 2. **Internal Testing**

Penetration Testing is a method of actively evaluating the security of an Information system or network by simulating an attack from a malicious source

PENETRATION TESTING

1. **Black box testing:** The tester has no prior knowledge of the infrastructure to be tested.
2. **White box testing:** The tester has complete knowledge of the infrastructure that needs to be tested is known.
3. **Grey box testing:** The tester usually has a limited knowledge of Information.

Method – Opportunity - Motive

- Attackers need MOM

- ❖ **Method**

- ✓ Skills, knowledge, tools, etc. with which to attempt an attack

- ❖ **Opportunity**

- ✓ Time and access to attempt an attack

- ❖ **Motive**

- ✓ A reason to attempt an attack

Cyber Criminal Motives

- ❖ Cyber criminal profiles and motives have changed over the years. Hacking started in the '60s with phone freaking (or phreaking) which refers to using various audio frequencies to manipulate phone systems.
- ❖ In the mid-'80s, criminals used computer dial-up modems to connect computers to networks and used password-cracking programs to gain access to data.
- ❖ Nowadays, criminals are going beyond just stealing information. Criminals can now use malware and viruses as high tech weapons.
- ❖ However, the greatest motivation for most cyber criminals is financial. Cybercrime has become more lucrative than the illegal drug trade.

Thwarting Cyber Criminals

- ❖ Thwarting the cyber criminals is a difficult task and there is no such thing as a “silver bullet.”
- ❖ However, company, government and international organizations have begun to take coordinated actions to limit or fend off cyber criminals.
- ❖ The coordinated actions include:
 1. Creating comprehensive databases of known system vulnerabilities and attack signatures
 2. Establishing early warning sensors and alert networks
 3. Sharing cyber intelligence information.
 4. Establishing information security management standards
 5. Enacting new laws to discourage cyberattacks and data breaches

Thwarting Cyber Criminals

1. Creating comprehensive databases of known system vulnerabilities and attack signatures (a unique arrangement of information used to identify an attacker's attempt to exploit a known vulnerability). Organizations share these databases worldwide to help prepare for and fend off many common attacks.
 - ✓ Vulnerability databases: the USA national common vulnerabilities and exposures (CVE) database is an example of the development of a national database.
<http://www.cvedetails.com/>

Thwarting Cyber Criminals

2. Establishing early warning sensors and alert networks. Due to cost and the impossibility of monitoring every network, organizations monitor high-value targets or create imposters that look like high-value targets. Because these high-value targets are more likely to experience attacks, they warn others of potential attacks.
 - ✓ The honeynet project is an example of creating early warning systems. The project provides a HoneyMap which display real-time visualization of attacks.
<https://www.honeynet.org/node/960>

Thwarting Cyber Criminals

3. Sharing cyber intelligence information. Business, government agencies and countries now collaborate to share critical information about serious attacks to critical targets in order to prevent similar attacks in other places. Many countries have established cyber intelligence agencies to collaborate worldwide in combating major cyberattacks.
 - ✓ InfraGard is an example of wide spread sharing of cyber intelligence. The InfraGard program is a partnership between the FBI and the private sector. The participants are dedicated to sharing information and intelligence to prevent hostile cyberattacks. <https://www.infragard.org/>

Thwarting Cyber Criminals

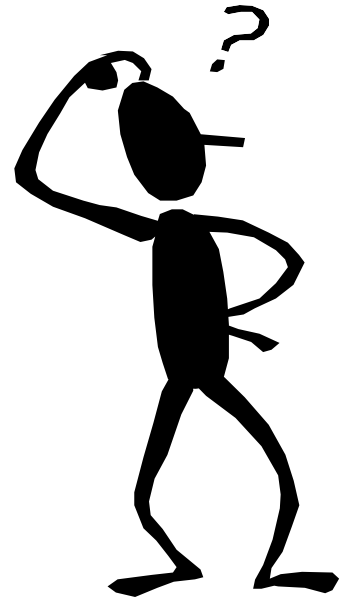
4. Establishing information security management standards among national and international organizations.
 - ✓ The ISO/IEC 27000 standard are an example of Information Security Management Standards. The standards provide a framework for implementing cybersecurity measures within an organization.
<http://www.27000.org/>
5. Enacting new laws to discourage cyberattacks and data breaches. These laws have severe penalties to punish cyber criminals caught carrying out illegal actions.
 - ✓ Cybercrime Act, 2015

Home Work

- 1. Write a short summary of history and evolution of cyber threats**

THANK YOU

END



ET 8202: LECTURE 04